

I. Introduction

a. Background of the Study

The healthcare industry is filled with important data and information made from different patients checking-in on the daily. A Health Information System (HIS) is a system that the healthcare industry uses to generate strategic information for the benefit of public health (PAHO, 2025). With different data and information being fed to the system, the cybersecurity aspect of healthcare is crucial. Attackers often look for exposed networks to have unauthorized access to patient and healthcare data. These attacks are often targeted at Health Information Systems due to the fact that they hold important and sensitive patient data and information that can help in saving patients. Attacks like advanced ransomware are often used on hospitals leading to unauthorized access to patients' health records which causes hospitals and clinics to turn to other facilities. With these attacks in the health care industry specifically on their Health Information Systems, IT Systems, and medical devices, many sensitive data such as patient medical records are leaked causing huge financial loss in the healthcare industry (Triplett, 2024).

With multiple attacks like Phishing and Ransomware still being continued today, healthcare industries spend more on security but are still vulnerable. To help mitigate these threats, healthcare institutions are adopting reliable practices that are approved under the Health Insurance Portability and Accountability Act (HIPAA). HIPAA is a federal law in the United States that sets privacy, security, and breach notification standards for protected health information (PHI) (Mindanao, 2025). HIPAA's frameworks and principles are being followed all over the Philippines (SeriousMD, 2025). Such security practices are risk analysis, training of employees on HIPAA regulations, regular audits and monitoring just to name a few

(Mindanao, 2025). With these standards and frameworks laid out by the HIPAA, the healthcare industry has a reliable security framework that helps in protecting important health information and data against adversaries.

b. Objectives of the Study

This review of related literature aims to achieve the following specific objectives:

- 1.) Recognize and assess the primary cybersecurity issues, risks, and weaknesses facing the healthcare sector today.
- 2.) Examine the documented IT security best practices, legal, and technological implementations within the healthcare system.
- 3.) Investigate the degree to which the existing security systems have been supplemented with new available technologies to strengthen the healthcare sector's cybersecurity weaknesses and the systems' overall resilience.

II. Methodology

This research uses a descriptive literature review approach to gather, analyze, and synthesize existing works regarding healthcare IT security. The review is bounded by the objectives of the three core themes: challenges, best practices, and developing issues.

A review of the literature was conducted within a range of peer-reviewed scholarly journals, industry publications from reputable firms in the cybersecurity area such as IBM Security, Palo Alto Networks, and Kaspersky, publications from governmental and regulatory organizations such as the U.S. Department of Health & Human Services, and the National Institute of Standards and Technology, and reliable technology news. Searches were conducted in digital scholarly databases such as

Google Scholar and IEEE Xplore and were limited to work produced between the years 2020 and 2025 to enhance relevancy.

Some of the primary search words were as follows: healthcare cybersecurity, HIPAA security compliance, ransomware in hospitals, IoMT security, AI in healthcare threat detection, health data privacy, and zero trust healthcare. The thematic analysis and synthesis of the literature was then used to tell a story in response to the research objectives, which eventually became the foundation of the Results and Discussion section.

III. Results and Discussion

a. Cybersecurity Threats in the Healthcare Industry

There are three (3) common cybersecurity threats that affect the healthcare industry the most. These three are Phishing, Ransomware, and Malware attacks (Thepsiri, 2024). According to the Health Insurance Portability and Accountability Act (HIPAA) which regulates the national standards that protect sensitive patient health information, Phishing is the leading cause of healthcare data breaches (Alder, 2024). Phishing is used to steal important credentials which allows unauthorized access to accounts that contain sensitive data. Phishing also leads to major financial losses for the healthcare industry. The average cost of a Phishing attack in the industry is \$14.8 million per year in the United States (Alder, 2024). Another attack that is connected to phishing is ransomware. In 2025, ransomware attacks in the healthcare industry increased by 30% (Moody, 2025). These attacks were directed at hospitals, clinics, and even healthcare providers. Attacks were also made on healthcare tech companies, pharmaceutical manufacturers, and medical billing providers. Hackers give access to sensitive information of a large organization through one central target and the industry faces ransomware from

different angles (Moody, 2025). The last common attack which also stems from phishing are malware attacks. Malwares that occur frequently in the healthcare industry are virus, worms, spyware, trojan, and an attack mentioned earlier, ransomware (Jegatheswaran, 2023). Ever since 2015, ransomware attacks have been increasing through the years and its effects in the industry are severe. Healthcare services such as delayed emergency services and delayed treatments to patients are happening due to ransomware attacks (Reed, 2025). These attacks on the healthcare industry cause harm to patients and institutions. It impacts and threatens the services being carried out by the healthcare industry which affects thousands and millions of lives in the process.

b. The Health Insurance Portability and Accountability Act (HIPAA)

The healthcare industry all over the world relies and follows on the standards and frameworks created by the Health Insurance Portability and Accountability Act (HIPAA). Most healthcare institutions strive to be HIPAA compliant. HIPAA compliance protects patient privacy and reduces the breach and audit risk in an institution. Along with HIPAA, Intelligent Technical Solutions helps in regulating organizations when it comes to assessing risk, training teams, and documenting cybersecurity evidence so factors such as audits run smoothly and healthcare operations stay secure (Mindanao, 2025).

HIPAA sets the standard for Protected Health Information (PHI) which are any patient personal information found in their medical or health records that can be used to identify them. The coverage of a Protected Health Information includes any details that are created, used or shared when doing healthcare services such as treating or regular check-ups (Berkeley, 2025).

c. Existing Best Practices and Security Frameworks

The HIPAA introduces standards that cover all aspects of an institution in the healthcare industry. The standards and frameworks prevent healthcare fraud and abuse and administrative simplification which is the reduction of complexity in business processes that makes the process more efficient and accessible. The following rules and standards are enforced in the healthcare industry and are being followed internationally.

Privacy Rule

The HIPAA Privacy Rule regulates how PHI may be used and disclosed by "covered entities" including healthcare providers, health plans, and healthcare clearinghouses, and it limits uses to those with a legitimate "need to know." Individuals have a right of access under the Rule to their PHI, and covered entities must provide access within 30 days of the request, with limited exceptions. Disclosures for treatment, payment, and healthcare operations may be made without a patient's prior written authorization, but other disclosures generally require an individual's written authorization, and disclosures should be based on the "minimum necessary" principle-only the smallest amount of information needed should be shared. The Privacy Rule also provides individuals with rights to request corrections, specify delivery methods, including electronic delivery, and direct disclosures to third parties, such as Personal Health Record services. Additional restrictions apply to certain categories of information, such as psychotherapy notes.

The 2013 Omnibus Rule was a major update that expanded protections-including the extension of privacy protection to certain entities and modification of breach analysis-and clarified a number of retention/protection

timelines. For instance, some of the requirements for the protection of PHI extend for a period beyond a patient's death. The Privacy Rule provides obligations related to accounting for disclosures, documenting privacy policies and procedures, and providing notices of privacy practices to patients. These privacy obligations provide much of the legal foundation for how healthcare organizations design workflows, training, and patient-facing services.

Transactions and Code Sets Rule

The Transactions and Code Sets Rule-developed under HIPAA's Administrative Simplification-standardizes common electronic healthcare transactions and the code sets used in them to improve administrative efficiency and interoperability. Examples include standardized electronic claims, eligibility inquiries, and remittance advice. Under this Rule, entities that submit or process electronic transactions must use the mandated standard formats and code sets so payers, providers, and clearinghouses can exchange information uniformly and dependably. This standard reduces manual paper work, accelerates reimbursement, and reduces administrative costs, while setting forth explicit technical expectations of any system handling claims and related administrative transactions.

Security Rule

Whereas the Privacy Rule addresses PHI more broadly, the HIPAA Security Rule explicitly deals with the safeguarding of electronic PHI (ePHI). Along the three safeguard areas of the Security Rule, which are administrative, physical, and technical, the Security Rule is structured. Administrative safeguards comprise documented procedures and policies, assignment of a security officer; training of the workforce; authorization of access; procedures for establishing, modifying, or terminating access; risk

assessment; system audits; periodic audits; data backup; strategies to recover from a disaster; and planning. The focus of physical safeguards is protecting the hardware and the access physically to the devices and storage (e.g., safe storage for servers, locks on doors to computer rooms, and restricted access to the disposal of physical records). Technical protections address system-based protections, such as access control, user identification, logging of system activity, control of data integrity, protection of data transmission, and other safeguards that ensure data confidentiality, integrity, and availability (CIA). These safeguards, especially requiring organizations to implement combinations of policies, physical facility controls, training of personnel, and systems technology, address the loss, unauthorized access, or unauthorized disclosure of ePHI and reduce ePHI risk.

In practice, the Security Rule requires healthcare organizations to perform continual risk assessments and to implement reasonable and appropriate measures tailored to their size, complexity, technical environment, and the costs of implementation. These requirements directly inform cybersecurity best practices in healthcare — such as robust identity management, encryption, regular patching, incident response planning, and employee training.

Unique Identifiers Rule

The Unique Identifiers Rule implements the NPI system, requiring covered entities to use the NPI when conducting standard electronic transactions. The NPI is a 10-digit identifier assigned to healthcare providers that replaced many different legacy identifiers used by payers and government programs but does not replace other regulatory identifiers such as DEA numbers or state license numbers. The NPI was intended to be a simple, non-intelligent identifier-it

carries no embedded information about the provider-and to enhance consistency in provider identification across electronic transactions and administrative databases. Using a single national identifier simplifies transaction processing and reduces ambiguity when claims and other administrative messages are exchanged among multiple organizations.

Enforcement Rule

The Enforcement Rule created civil monetary fines and rules surrounding investigations, compliance review, and hearings pertaining to HIPAA. HHS, specifically OCR, is the HIPAA enforcement body and has investigated thousands of potential violations, settling on many by requiring the defendant to resubmit to the agency accompanied by a plan outlining the corrective actions required and modifications to the defendant's privacy and security practices. If a violation is declared, enforcement actions range from the required actions to be taken, civil monetary fines depending on the severity of the violation, and even the possibility of a referral to a criminal prosecution if the situation is deemed serious enough. Because of the Enforcement Rule, covered entities have both motivation and legal structuring to ensure the implemented privacy and security required by HIPAA.

d. Emerging Trends and Technologies

New and emerging technologies are being implemented in the healthcare industry to secure patient data and healthcare systems such as Health Information Systems however, some technologies still present security challenges that can be exploited by attackers (Aldosari, 2025).

The Internet of Things (IoT) has introduced many concepts of security in the field of healthcare. The connection of different medical devices and equipment in the industry to the internet enables multiple

features such as real-time data sharing and data monitoring. However, this emerging technology poses major security risks such as hacking and unauthorized access. Healthcare IT teams and manufacturers are trying to create efficient and secure security mechanisms backed up with reliable data encryption, and continuous monitoring and system updates (Aldosari, 2025).

Cloud computing is the front-runner of emerging technologies in the healthcare industry. This emerging technology also expanded access to healthcare services specifically on telemedicine (Kedi et al, 2024). Healthcare institutions are also adopting cloud computing for data storage and accessibility, scalability and flexibility. But there are still challenges that can affect the integration of cloud computing in healthcare systems. Cloud computing is a complex system and teams must emphasize access controls, encryptions, and contractual agreements with cloud providers. Healthcare institutions risk trusting cloud providers with stored records in their system (Aldosari, 2025).

The last emerging technology that the healthcare industry integrates into their systems are artificial intelligence and machine learning. These emerging technologies have transformed treatment planning, diagnostics, and drug discovery. This technology processes huge amounts of clinical data and algorithms can identify patterns and predict medical outcomes with accuracy. However, with the implementation of Artificial Intelligence, technologies integrated with AI demands a large number of datasets which raises privacy and data security concerns (Aldosari, 2025).

With these emerging technologies being implemented to strengthen and help security in healthcare, there are still security challenges and loopholes that the

healthcare industry faces. The HIPAA are implementing strict security measures and standards for protecting this sensitive patient information.

IV. Conclusion

This research emphasizes the significance of cyber security in today's healthcare industry. The amount of cyber-attacks such as malwares, ransomware, phishing attacks are the threats our healthcare industry is facing which poses a risk for the safety of the patients and will create issues in healthcare operations. These risks have exposed countless weaknesses in the Health Information Systems and have clarified that the need to strengthen the health data of our healthcare industry is important. These cyber-attack incidents do not only interrupt healthcare operations but they also put many patients at risk which shows the urgency in strengthening cybersecurity measures.

In providing safe healthcare operations, the regulations regulating the Health Insurance Portability and Accountability Act (HIPAA), particularly the Security Rule are crucial. The same standards that regulate the PHI are the source of risk management or safety and security protocols. Rules about privacy, security, transactions, enforcement, and administrative simplification provides a complete structure for constructing secure workflows.

Cyber security remains a necessity for protecting the data of healthcare patients and ensuring that their healthcare operations stay secure. To strengthen their healthcare systems, hospitals and clinics should use the insights from this study such as proven strategies, the use of emerging technologies. To maintain the trust and protect the patients, healthcare institutions must use innovative solutions to address the risks. Healthcare institutions must strengthen their security by investing in

improved security practices that can guarantee the safeguard of patient's privacy and support the advancement of healthcare.

References:

Alder, S. (2024, January 6). *Healthcare Data Breaches Due to Phishing*. HIPAA Journal. <https://www.hipaajournal.com/healthcare-data-breaches-due-to-phishing/>

Convocar, J. M. (2023, April 14). *7 Best Security Practices for HIPAA Compliance [Updated]*. Wwww.itsasap.com. <https://www.itsasap.com/blog/hipaa-security-best-practices>

Edemekong, P., Haydel, M., & Annamaraju, P. (2024). *Health Insurance Portability and Accountability Act (HIPAA)*. National Library of Medicine. <https://www.ncbi.nlm.nih.gov/books/NBK5000>

Health information systems. (2025b, October 29). PAHO/WHO | Pan American Health Organization. <https://www.paho.org/en/topics/health-information-systems>

Kedi, E., None Chibundom Ejimuda, & None Mojeed Dayo Ajegbile. (2024). Cloud computing in healthcare: A comprehensive review of data storage and analysis solutions. *World Journal of Advanced*

Engineering Technology and Sciences, 12(2), 290–298. <https://doi.org/10.30574/wjaets.2024.12.2.0291>

Reed, J. (2025, January 30). *When ransomware kills attacks on healthcare facilities*. Ibm.com. <https://www.ibm.com/think/insights/when-ransomware-kills-attacks-on-healthcare-facilities>

SeriousMD is HIPAA-compliant. What does that mean? / *SeriousMD Doctors Help Center / Guides & FAQ*. (2025). Seriousmd.com. <https://help.seriousmd.com/en/articles/1079965-seriousmd-is-hipaa-compliant-what-does-that-mean>

Thepsiri, T. (2025b, September 10). *Cybersecurity in healthcare- top threats & best practices*. <https://www.kelsercorp.com/blog/it-security-healthcare-common-threats-best-practices>

Triplett, W. J. (2024). Cybersecurity vulnerabilities in healthcare: a threat to patient security. *Triplett / Cybersecurity and Innovative Technology Journal*. <https://doi.org/10.53889/citj.v2i1.333>

UC Berkeley. (2025). *HIPAA PHI: Definition of PHI and list of 18 identifiers*. Berkeley.edu. <https://cphs.berkeley.edu/hipaa/hipaa18.html>

